BOTIUM TOYS

Internal Security Audit & Risk Assessment Deliverable

INHERENT RISK: 8/10

NIST CSF 2.0 / PCI DSS

TO:	IT Manager, CISO & Executive Leadership — Botium Toys	**DATE:**	November 5, 2026
FROM:	**Eduardo de Souza Marques** — Cybersecurity & GRC Analyst	**STANDARDS:**	NIST CSF 2.0, PCI DSS v4.0, GDPR, SOC 2
SUBJECT:	Internal Security Audit Findings, Regulatory Exposure & Remediation Roadmap		

🚨 **Executive Risk Alert:** Botium Toys currently maintains an unacceptable inherent risk posture scored at **8 / 10 (High Risk)**. While baseline perimeter firewalls and physical facility controls are operational, critical deficiencies in data protection, access governance, disaster recovery, and regulatory compliance leave the company exposed to catastrophic breach liabilities, merchant processing suspension, and operational insolvency.

1. EXECUTIVE SUMMARY & AUDIT SCOPE

Following the commercial expansion of Botium Toys' retail storefront, warehouse operations, and international e-commerce channels, an internal security audit was performed across all physical, network, system, and data assets. The objective is to identify security deficiencies, calculate inherent operational risk, evaluate regulatory exposure, and establish an actionable remediation roadmap.

Asset Inventory & Classification

- **Tier 1 — Data Assets (Critical):** Customer Primary Account Numbers (PANs), expiration dates, and PII/SPII. *Status: Unencrypted, stored locally in plaintext with unrestricted employee access.*
- **Tier 1 — Transactional Systems (Critical):** Production relational databases and e-commerce payment web application. *Status: Active firewall protection; lacking database encryption and intrusion detection.*
- **Tier 2 — Endpoints & Workforce (High):** Laptops, warehouse workstations, and remote devices. *Status: Antivirus active; weak password rules, lacking centralized IAM and MFA.*
- **Tier 2 — Legacy Systems (High):** End-of-life accounting and inventory infrastructure. *Status: Monitored manually; unsegmented; no formal patch cadence.*
- **Tier 3 — Facilities (Medium):** Retail storefront, executive offices, and fulfillment warehouse. *Status: Fully secured with deadbolts, CCTV surveillance, and compliant fire systems.*

2. CONTROLS ASSESSMENT MATRIX

The audit evaluated 16 foundational security controls across technical, administrative, and physical domains:

Security Control Name	Type	Status	Observed Technical Finding / Gap
Principle of Least Privilege	Technical	MISSING	All employees have unrestricted access to internal data and cardholder records.
Separation of Duties	Admin	MISSING	Operational leadership and payroll/financial tasks overlap without independent checks.
Data Encryption (At Rest)	Technical	MISSING	Credit cards and customer PII are stored in plain text inside local database servers.
Data Encryption (In Transit)	Technical	MISSING	Internal transactional traffic and API data flows lack mandatory TLS 1.3 encryption.

Security Control Name	Type	Status	Observed Technical Finding / Gap
Password Complexity Policy	Admin	MISSING	Requirements are nominal; does not enforce minimum length, rotation, or complexity.
Centralized IAM & Password Management	Technical	MISSING	No centralized directory (SSO/IAM); password recovery tickets cause severe IT friction.
Multi-Factor Authentication (MFA)	Technical	MISSING	Single-factor password only on endpoints, administrative dashboards, and remote access.
Intrusion Detection System (IDS)	Technical	MISSING	No NIDS or HIDS deployed; blind to real-time internal attacks or data exfiltration.
Disaster Recovery Plan (DRP) & BCP	Admin	MISSING	No documented business continuity plan, RTO, or RPO to survive an outage.
Automated Data Backups	Technical	MISSING	Zero automated or offsite backups; a ransomware attack would cause permanent data loss.
Legacy System Maintenance Schedule	Operational	MISSING	End-of-life legacy systems lack regular patch intervals and defined intervention rules.
Stateful Firewall	Technical	ACTIVE	Properly configured rule-based filtering actively blocking unauthorized network traffic.
Antivirus & Anti-Malware	Technical	ACTIVE	Installed across corporate workstations and monitored regularly by IT.
Physical Locks & Access Controls	Physical	ACTIVE	Functional deadbolts and controlled key access across offices and warehouse.
Closed-Circuit TV (CCTV)	Physical	ACTIVE	Surveillance cameras monitoring store perimeter, entrance, and warehouse storage.
Fire Detection & Suppression	Physical	ACTIVE	Compliant smoke detectors and fire suppression systems installed across premises.

3. REGULATORY COMPLIANCE & PENALTY EXPOSURE

Due to its international e-commerce growth, Botium Toys operates under strict regulatory frameworks:

- **PCI DSS v4.0 (Non-Compliant — Critical Exposure):** Violates Requirement 3 (storing unencrypted primary account numbers) and Requirement 4 (unencrypted transmission). *Potential Liability:* Fines of $5,000 to $100,000/month by card payment brands, mandatory forensic investigation costs, and revocation of credit card processing capabilities.
- **GDPR (Non-Compliant — Severe Legal Exposure):** Processing European customer PII without encryption or access controls violates Articles 25 and 32. While a 72-hour breach concept exists, no tested incident response plan is documented. *Potential Liability:* Administrative fines up to €20 million or 4% of total worldwide annual turnover.
- **SOC 1 & SOC 2 Type II (Deficient):** Fails Trust Services Criteria for Security and Confidentiality. Segregation of duties is absent between executive operations and financial accounting. *Potential Liability:* Inability to secure enterprise B2B retail partnerships and severe valuation impairment.

4. PRIORITIZED ACTIONABLE REMEDIATION ROADMAP

> 🎯 **Remediation Objective:** Transition Botium Toys from a reactive, high-risk posture (8/10) to a resilient, audit-ready defense-in-depth architecture with a residual risk score of **2 / 10 (Low Risk)**.

Phase 1: Immediate Containment (Days 0 – 30) — Priority: CRITICAL

- **Least Privilege & RBAC:** Immediately restrict database and cardholder data access strictly to authorized accounting/billing personnel based on job roles.
- **Database & Transport Encryption:** Implement AES-256 encryption at rest for customer databases; mandate TLS 1.3 across all e-commerce transactions and internal APIs.
- **Emergency Backup Protocol:** Establish daily offsite, immutable database backups (adhering to the 3-2-1 backup principle) to immediately mitigate ransomware failure risks.

Phase 2: Posture Hardening & Detection (Days 30 – 90) — Priority: HIGH

- **Deploy Intrusion Detection (IDS):** Install a Network-based IDS (NIDS) alongside the firewall and deploy endpoint detection (EDR) to identify malicious traffic and anomalies in real time.
- **Centralized IAM & Mandatory MFA:** Implement an enterprise password manager/directory service enforcing 12+ character passphrases, automated lockout policies, and Multi-Factor Authentication.
- **Legacy System Isolation:** Segment all end-of-life legacy accounting modules onto an isolated VLAN with strict ACLs to prevent lateral compromise.
- **Disaster Recovery Plan (DRP):** Formulate a formal Disaster Recovery Plan establishing documented Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO).

Phase 3: Governance & Audit Attestation (Days 90 – 180) — Priority: STRATEGIC

- **PCI DSS Validation:** Complete formal Self-Assessment Questionnaire (SAQ-D) and acquire formal Attestation of Compliance (AoC).
- **GDPR Privacy Workflows:** Formalize Data Protection Impact Assessment (DPIA) procedures and test the 72-hour incident notification workflow with tabletop exercises.
- **Independent Security Testing:** Commission third-party external penetration testing and SOC 2 Type I readiness assessments.